LL-IR-PRODUCTOS FERNANDEZ

EGS

Nota de Confidencialidad
Este documento contiene información confidencial de propiedad de EGS
EGS acuerda mantener esta información confidencial y no reproducirla o darla a conocer a ninguna persona fuera del grupo directamente responsable de la evaluación de su contenido.

Contenido

1 Información General del Incidente 2

2 Resumen Ejecutivo 3

3 Gestión del incidente y NIST SP 800-61 4

3.1 Preparación 4

3.2 Detección y Análisis 4

3.3 Contención, Erradicación y Recuperación 7

3.4 Lecciones Aprendidas y próximos pasos 8

3.5 Estadísticas sobre Incidente 8

3.6 Conclusiones 9

3.7 Configuraciones recomendadas según Línea Base de Seguridad Firebox 11

1 Información General del Incidente

Incidente Mayor en Productos Fernandez	
Fecha y hora de reporte del incidente:	23-10-25 10:26 (UTC -3)
Fecha y hora de confirmación del incidente:	23-10-25 10:26 (UTC -3)
Caso de CRM EGS – 1	CAS-188914-Q0V4F
Nombre del informante	Alvaro Soto

2 Resumen Ejecutivo

El presente informe detalla el incidente de ciberseguridad ocurrido en la empresa **Productos Fernández**, estructurado según las fases recomendadas por el marco NIST SP 800-61 https://es.linkedin.com/advice/3/how-can-you-use-nist-sp-800-61-framework-effectively?lang=es.

A fines de octubre de 2025, la empresa **Productos Fernández** experimentó un **ataque de denegación de servicio (DDoS)** que afectó temporalmente el rendimiento de algunos servicios conectados a internet. El incidente fue detectado por un **servicio de monitoreo de seguridad externo (SOC)**, que alertó al equipo de tecnología de **Productos Fernández**.

Gracias a la **rápida respuesta del equipo TI de Productos Fernández**, se logró confirmar el ataque y coordinar con **EGS** una **investigación forense** en el firewall perimetral de la organización.

El análisis posterior de los registros y eventos permitió identificar los **orígenes del ataque** y los **países desde donde se generaron las conexiones maliciosas**, además de otros datos relevantes que continúan bajo revisión.

El informe incluye **recomendaciones concretas** para **reforzar la seguridad de la infraestructura** de **Productos Fernández**, en línea con las **buenas prácticas del marco NIST SP 800-61**, con el objetivo de prevenir futuros incidentes similares y servir como referencia para otras empresas.

Impacto del incidente:
Según la información preliminar entregada por **Productos Fernández**, el ataque provocó **demoras y lentitud** en algunos servicios accesibles desde internet entre el **22 y el 27 de octubre de 2025**. Sin embargo, **no se registraron daños ni interrupciones** en las aplicaciones principales ni pérdida de información.

3 Gestión del incidente y NIST SP 800-61

3.1 Preparación

Productos Fernandez en la persona de Alvaro Soto apertura un caso con EGS para obtener apoyo sobre un evento reportado por su servicio de SOC asociado a ataques de **DDoS.**

Nos reporta que aproximadamente a las 20:54 recibe alerta de SOC sobre un aparente intento de ataque de DDoS proveniente de la IP 223.123.92.149.

3.2 Detección y Análisis

Luego de la información provista por Alvaro Soto, se inicia la búsqueda de logs asociados a esta IP 223.123.92.149, esta investigación inicial arrojo resultados en el rango del 13 al 22 de octubre del 2025, lo cual coincide con la fecha de la ocurrencia. La mayor parte del tráfico fue denegado hasta la fecha 22-10, luego se observa cierto tráfico permitido asociado al puerto TCP 443. De acuerdo con el portal Cisco Talos esta IP esta identificada como maliciosa y se ubica en **Pakistán.**

Reputation Lookup || Cisco Talos Intelligence Group - Comprehensive Threat Intelligence.

Tabla resumen de eventos identificados por Protocolo:

Protocolo	Puerto de Destino	Descripción del Tráfico Denegado
HTTP (TCP)	80	Se registran varios intentos de conexión HTTP (puerto 80) a múltiples IPs de destino (200.50.124.132, 190.208.2.231, 190.13.160.73, etc.). Estos paquetes fueron denegados.
TELNET (TCP)	23	Se observan intentos de conexión al servicio inseguro TELNET (puerto 23) dirigidos a diferentes IPs (190.208.2.231, 200.68.43.172, 200.50.124.133). Todos fueron denegados. NOTA DE SEGURIDAD: El protocolo Telnet no cifra el tráfico y su uso debe ser evitado o bloqueado por completo, lo cual el firewall está haciendo con éxito.
HTTPS (TCP)	443	También se deniegan algunas peticiones HTTPS (puerto 443) dirigidas a IPs específicas.
Docker Remote API (TCP)	2375	Hay tráfico denegado al puerto 2375, que corresponde al API remoto no cifrado de Docker. NOTA DE SEGURIDAD: La exposición de este puerto (2375) a Internet es un riesgo de seguridad conocido y es positivo que el firewall lo esté denegando.

Puerto Inusual (TCP)	2222	Intentos denegados al puerto 2222, posiblemente un puerto SSH alternativo o un servicio de administración.

Sobre esta IP puede concluir lo siguiente:

- La dirección IP de origen 223.123.92.149 parece ser una fuente de tráfico legítimo **(Permitido)** dirigido a servicios internos de la compañía (posiblemente una API o un portal web, dada la traducción a IPs privadas 172.x.x.x) que utilizan HTTPS y son inspeccionados por un proxy.
- Sin embargo, esta misma IP también genera una cantidad significativa de **Tráfico Denegado**, que incluye escaneo o intentos de conexión a puertos de alto riesgo como **TELNET (23)** y la **Docker API no cifrada (2375)**

Alvaro Soto informa que luego de este primer bloqueo realizado, también se reciben múltiples intentos desde las siguientes direcciones: **177.38.0.0/16, 159.60.0.0./16, 45.234.0.0./16**

La búsqueda de logs asociados al bloque de direcciones **177.38.X.X** arrojo resultados en el rango del 13 al 22 de octubre que coincide con la fecha de la ocurrencia, tráfico permitido asociado al puerto **UDP 53** y **TCP 443**. De este bloque de IPs podemos indicar que una muestra tomada de las IPs permitidas durante el periodo evaluado corresponde a IPs ubicadas en **Brasil**.

Sobre esta IP se puede concluir lo siguiente:

- La mayor parte del tráfico asociado a este bloque de IPs parece ser una fuente legitima **(Permitido)** hacia los protocolos **TCP 443** y **UDP 53**.
- El mayor tráfico de estos puertos se registra a través de las siguientes políticas **SNAT BALANCEADOR DE CARGA_HTTPS, SNAT_tienda_pf_alimentos_bckp, SNAT SERV DECLAJURADA BCKP,Acc APP Clientes_test_443, SNAT_DNS_PUBLICOS_BCKP y Snat DNS_2**
- Se identifican dominios específicos en el *Server Name Indication* (SNI) del tráfico HTTPS, lo que indica que el tráfico va dirigido a servicios de la compañía, tales como: **comercialcerrillos.cl, pfalimentos.cl, coce.cl**, y subdominios como **coce.pfalimentos.cl**
- Sobre las negaciones asociadas a este bloque de IPs están asociados a los puertos **TCP 25** y **TCP 587**. Los intentos a los puertos **TCP 25** y **TCP 587** son denegados por la política no manejada, lo cual es correcto si el tráfico no debe ser dirigido a un servidor de correo interno expuesto a esta red de origen. La IP de origen 177.38.181.160 fue la fuente de estos intentos

La búsqueda de logs asociados al bloque de IPs **159.60.X.X** arrojo resultados en el rango del 13 al 22 de octubre que coincide con la fecha de la ocurrencia, tráfico permitido principalmente asociado al puerto **UDP 53** y **TCP 443**. De este bloque de IPs podemos indicar que una muestra tomada de las IPs permitidas durante el periodo evaluado corresponde a IPs ubicadas en **India, Israel y Canadá.**

Sobre esta IP se puede concluir lo siguiente:

- Se trata de consultas DNS desde múltiples IPs de este bloque de direcciones dirigida hacia su IP expuesta **190.54.44.149**
- La política que permite este tráfico principalmente es **SNAT_DNS_PUBLICOS_BCKP**
- Las consultas son para los dominios de la compañía, incluyendo **www.pfalimentos.cl, ns.pf.cl y ns2.pf.cl**
- Sobre el acceso por HTTPS podemos centrar los intentos a su IP publica **190.171.167.152** a través de la política **SNAT_BALANCEADOR_CARGA_HTTPS_BCKP**

La búsqueda de logs asociados al bloque de IPs **45.234.X.X** arrojo resultados en el rango del 13 al 22 de octubre que coincide con la fecha de la ocurrencia, tráfico permitido principalmente asociado al puerto **UDP 53** y **TCP 443**. De este bloque de IPs podemos indicar que una muestra tomada de las IPs permitidas durante el periodo evaluado corresponde a IPs ubicada en **Brasil.**

Sobre esta IP se puede concluir lo siguiente:

- La mayor parte de los accesos de este segmento son a través del puerto protocolo HTTPS

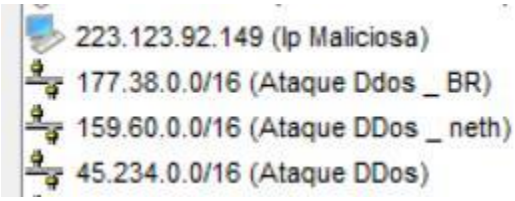
Política (Policy)	Descripción del Servicio (Traducción NAT a)
SNAT BALANCEADOR DE CARGA_HTTPS-00	Tráfico dirigido al Balanceador de Carga principal (172.10.10.100) .
SNAT_tienda_pf_alimentos_bckp-00	Tráfico dirigido a la Tienda o E-commerce de PF Alimentos (172.10.10.155) .
SNAT SERV DECLAJURADA BCKP-00	Acceso al servicio de Declaración Jurada de Respaldo (172.10.10.79) .
SNAT_apictradicional-00	Acceso a la API Tradicional (ej. 172.10.10.83 en puerto 8443 o 8444) .
SNAT_trsdl-gw.pfalimentos.cl_bckp-00	Acceso al Gateway Transaccional de Respaldo (172.10.10.110) .

- También se registran consultas DNS desde múltiples IPs de este bloque de direcciones dirigida hacia su IP expuesta **190.54.44.149**
- La política que permite este tráfico principalmente es **SNAT_DNS_PUBLICOS_BCKP**
- Las consultas son para los dominios de la compañía, incluyendo **www.pfalimentos.cl, ns.pf.cl y ns2.pf.cl**
- Aproximadamente a partir de las 21:50hrs se observa el bloqueo de los accesos asociados a esta IP por la lista de bloqueos, lo que coincide con la hora en que fue aplicado el bloqueo por su parte.

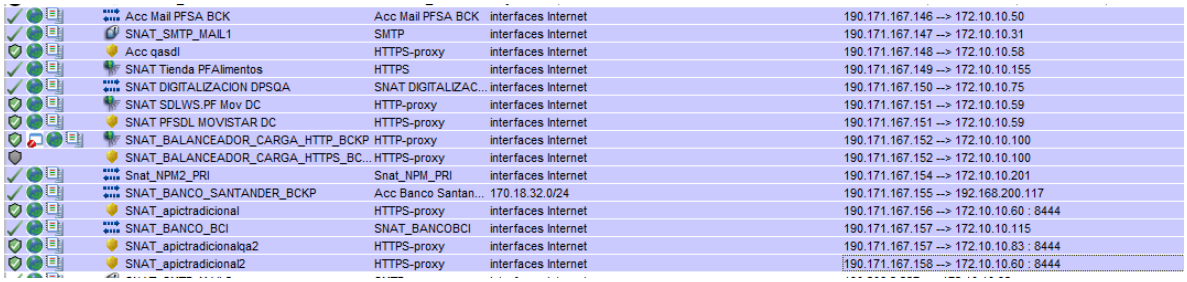
3.3 Contención, Erradicación y Recuperación

Acciones realizadas en Firebox:

- Bloqueo de IP maliciosa: El SOC de PF Alimentos detectó una IP maliciosa y procedió a bloquearla mediante Blocked Sites. Evidencia:



- Bloqueo de georeferenciación: Se bloqueo contenido desde todo el mundo excepto Chile para las políticas mostradas. Evidencia:



Acc Mail PFSA BCK	Acc Mail PFSA BCK	interfaces Internet	190.171.167.146 --> 172.10.10.50
SNAT_SMTP_MAIL1	SMTP	interfaces Internet	190.171.167.147 --> 172.10.10.31
Acc qasdl	HTTPS-proxy	interfaces Internet	190.171.167.148 --> 172.10.10.58
SNAT Tienda PFAlimentos	HTTPS	interfaces Internet	190.171.167.149 --> 172.10.10.155
SNAT DIGITALIZACION DPSQA	SNAT DIGITALIZAC...	interfaces Internet	190.171.167.150 --> 172.10.10.75
SNAT SDLWS.PF Mov DC	HTTP-proxy	interfaces Internet	190.171.167.151 --> 172.10.10.59
SNAT PFSDL MOVISTAR DC	HTTPS-proxy	interfaces Internet	190.171.167.151 --> 172.10.10.59
SNAT_BALANCEADOR_CARGA_HTTP_BCKP	HTTP-proxy	interfaces Internet	190.171.167.152 --> 172.10.10.100
SNAT_BALANCEADOR_CARGA_HTTPS_BC...	HTTPS-proxy	interfaces Internet	190.171.167.152 --> 172.10.10.100
Snat_NPM2_PRI	Snat_NPM_PRI	interfaces Internet	190.171.167.154 --> 172.10.10.201
SNAT_BANCO_SANTANDER_BCKP	Acc Banco Santan...	170.18.32.0/24	190.171.167.155 --> 192.168.200.117
SNAT_apictradicional	HTTPS-proxy	interfaces Internet	190.171.167.156 --> 172.10.10.60 : 8444
SNAT_BANCO_BCI	SNAT_BANCOBCI	interfaces Internet	190.171.167.157 --> 172.10.10.115
SNAT_apictradicionalqa2	HTTPS-proxy	interfaces Internet	190.171.167.157 --> 172.10.10.83 : 8444
SNAT_apictradicional2	HTTPS-proxy	interfaces Internet	190.171.167.158 --> 172.10.10.60 : 8444

3.4 Lecciones Aprendidas y próximos pasos

Se definen los siguientes pasos a ejecutar según VB de PRODUCTOS FERNANDEZ sobre el caso en progreso, estos acuerdos se indican en sesión de Revisión del día 24/10/2025:

Ajustes aplicar de forma inmediata:

- Ajuste de parámetros de paquetes: Disminuir la cantidad de paquetes por defecto de 200 a 100 por segundo para limitar los intentos de conexión desde cualquier origen. Evaluar continuamente este parámetro según la aplicación o servicio publicado.
- Perfil de geolocalización más estricto: Habilitar un perfil de geolocalización que incluya los orígenes de las IPs que realizaron el ataque (Pakistán, China, Rusia, Brasil, etc.) para cortar cualquier intento de conexión desde esos países.
- Habilitación de servicios de seguridad: Habilitar servicios de seguridad en las políticas donde no estén, especialmente IPS, Full Scan y asegurar que el Botnet Detection esté habilitado.

Ajustes para realizar con Plan de trabajo programado:

- Transitar de reglas de filtro de paquetes a reglas Proxy, considerar como primeras reglas a modificar:

9	Snat_NPM2_PRI	Snat_NPM_PRI	interfaces Internet	190.171.167.154 --> 172.10.10.20
10	Snat_NPM2_RESP	Snat_NPM_PRI	interfaces Internet	190.13.160.76 --> 172.10.10.201
11	Snat_NPM_PRI	Snat_NPM_PRI	interfaces Internet	190.208.2.232 --> 172.10.10.200
12	Snat_NPM_RESP	Snat_NPM_PRI	interfaces Internet	190.82.90.35 --> 172.10.10.200

- Access portal: Utilizar un portal intermediario (Access Portal) para autenticación y reverse proxy antes de acceder a los servicios expuestos, similar a un ZTNA.
- Implementar un WAF (Web Application Firewall): Considerar la implementación de un WAF, como Cloudflare, para proteger a nivel de aplicación, ya que el firewall por sí solo tiene limitaciones para mitigar ataques DDoS.
- DNSWatch: Habilitar DNSWatch para identificar ataques basados en DNS.
- Autenticación multifactor: Agregar una capa adicional de autenticación con autenticación multifactorial hacia los usuarios.

Plan de trabajo propuesto especifico, por revisar y acordar fechas concretas: Plan de Trabajo estandar.xlsx

3.5 Estadísticas sobre Incidente

1. Top 10 de IPs Destino (Eventos y Porcentaje)

Este cuadro muestra los puntos de la infraestructura que reciben la mayor carga de tráfico, lo que es **crítico para el análisis de DDoS/DoS**, ya que revela los **objetivos primarios.**

Rank	IP Destino	Descripción Potencial	Eventos	Porcentaje (%)
1	190.82.90.36	**Balanceador de Carga / Gateway Principal / SITIO WEB**	144,228	62.06%
2	190.54.44.149	**Servidor DNS Principal / Externo**	50,58	21.77%
3	190.208.2.233	Servidor Trsdl / Gateway de Servicios	12,989	5.59%
4	190.171.167.156	Servidor APIC (API/Aplicaciones)	8,883	3.82%
5	190.82.90.179	Servidor Tienda / Servicio E-commerce	5,042	2.17%
6	190.82.90.37	Servidor CRM/Servicio de Negocio	3,98	1.71%
7	190.171.167.100	Host de DMZ (Diversos Servicios)	2,78	1.20%
8	200.50.124.132	Destino de Tráfico Denegado (No Manejado)	153	0.07%
9	190.82.90.100	Otro Host de DMZ	82	0.04%
10	190.82.90.35	Otro Host de DMZ	78	0.03%
TOTAL Top 10			228,895	98.46%

Análisis de Seguridad (DDoS):

- **Riesgo Crítico:** La IP 190.82.90.36 **(Balanceador de Carga - Sitio WEB)** es el destino de la inmensa mayoría del tráfico (más del **62%**). Este es el **punto de fallo único más importante** y el objetivo más probable para cualquier ataque de saturación (DDoS/DoS) que busque la **denegación total del servicio.**
- **Ataque a Infraestructura:** La IP 190.54.44.149 **(DNS)** concentra el **21.77%** del tráfico. Un atacante podría usar consultas DNS legítimas o malformadas para saturar la capacidad de resolución de nombres, lo que afectaría indirectamente a todos los demás servicios.

2. Top 10 de IPs Origen (Eventos y Porcentaje)

Este cuadro identifica las fuentes individuales más activas que contribuyen al volumen total, esencial para aislar los "**atacantes**" o los **clientes/servidores internos anómalos**.

Rank	IP Origen	Segmento	Eventos	Porcentaje (%)
1	159.60.166.4	159.60.X.X	49,709	21.39%
2	159.60.168.185	159.60.X.X	37,705	16.22%
3	159.60.167.123	159.60.X.X	24,195	10.41%
4	159.60.169.185	159.60.X.X	20,405	8.78%
5	159.60.168.125	159.60.X.X	19,985	8.60%
6	159.60.168.105	159.60.X.X	18,485	7.95%
7	159.60.169.199	159.60.X.X	15,315	6.59%
8	45.234.106.1	45.234.X.X	10,131	4.36%
9	177.38.106.4	177.38.X.X	3,04	1.31%
10	45.234.104.168	45.234.X.X	1,719	0.74%
TOTAL Top 10			200,694	86.35%

Análisis de Seguridad (DDoS):

- **Fuentes Sospechosas:** Las **siete principales IPs de origen provienen del segmento 159.60.X.X**, representando un abrumador **80%** del tráfico, estos segmentos han sido identificados como propiedad del fabricante F5 el cual es un importante proveedor de servicios Cloud. La sospecha de DDoS debe concentrarse aquí. Si estas siete IPs son, de hecho, *servidores internos* o *gateways* con un alto volumen de actividad legítima, la actividad es normal. Sin embargo, si son múltiples **clientes/dispositivos distribuidos**, el patrón de alto volumen concentrado es un **indicador primario de ataque DDoS L7**.
- **IP de Alerta (DDoS L7):** La IP 159.60.168.185 (Rank 2) ya fue identificada como la fuente de **logs de Error SSL/TLS**. Su alto volumen total (**37.705 logs**) le otorga la capacidad de lanzar un ataque de capa 7 que consume recursos con *handshakes* fallidos.

3. Distribución de Eventos por Fecha (13/10 al 22/10)

Este cuadro busca identificar picos o anomalías de tráfico por día, lo que es un indicador temporal clave de un ataque de saturación (DDoS).

Fecha	Eventos (logs)	Variación (%)*	Observación de Seguridad
13/10/2025	25,291	N/A	Alto volumen de inicio.
14/10/2025	21,114	-16.51%	Descenso esperado post-fin de semana/inicio de semana.
15/10/2025	23,78	+12.63%	Estabilización del volumen en día laboral.
16/10/2025	27,477	+15.55%	PICO MÁXIMO DEL PERIODO.
17/10/2025	24,845	-9.58%	Volumen alto, pero con leve descenso respecto al pico.
18/10/2025	24,115	-2.94%	Volumen en descenso.
19/10/2025	22,43	-7.07%	Descenso hacia el fin de semana.
20/10/2025	17,005	-24.27%	PUNTO MÍNIMO DEL PERIODO (Fin de semana).
21/10/2025	23,387	+37.53%	Gran repunte de tráfico para el inicio de semana.
22/10/2025	22,954	-1.85%	Estabilización.
TOTAL	232,398		

*Variación calculada respecto al día anterior.

Análisis de Seguridad (DDoS):

- **Pico Anómalo:** El día **16/10** registra el **pico máximo de tráfico (27.477 logs)** cuyo origen está en el segmento **159.60.X.X**.
- **Comportamiento Cíclico:** La distribución muestra un **claro patrón cíclico de días hábiles/fin de semana**. El volumen máximo es cerca de logs/día y el mínimo alrededor de logs/día.

Conclusiones

- **Punto Único de Fallo (Single Point of Failure):** El **Balanceador de Carga (190.82.90.36)** es el destino principal del **62.06%** del tráfico total, confirmando que es el recurso más crítico y donde cualquier ataque o fallo tendrá el mayor impacto.
- **Segmento Crítico:** El segmento **159.60.X.X** es responsable del **80%** del tráfico de las 10 IPs de origen más activas. Este tráfico es la principal fuente de carga y de anomalías de seguridad (Error SSL/TLS).
- **Tráfico Cíclico:** El análisis horario del día pico (16/10) confirma que el patrón de tráfico general es **típico de una jornada laboral** (pico 9:00-10:00, caída 12:00-13:00), descartando la aleatoriedad y el volumen masivo de un DDoS tradicional.

- De acuerdo con los datos obtenidos hasta el momento, durante el periodo estudiado se observaron elementos de tráfico que pueden ser **catalogados como intentos de conexión desde IP maliciosas**, no obstante, el estudio especifico desde el día 13/10/2025 hasta el 22/10/2025 no permiten concluir que esto se deba a un DDOS o al menos no como un ataque distribuido en curso.
- Para poder continuar con la investigación se sugiere disponibilizar los parámetros de ajuste que dispone el SOC Externo y con ello igualar las configuraciones de manejo de paquetes en el Firewall.
- Mantenemos en investigación este evento, con el apoyo de nuestro partner WatchGuard. Cuando podamos contar con los resultados de la investigación detallada de WatchGuard se podrán comparar con los primeros análisis hechos por EGS, lo cual permitirá fortalecer la toma de decisiones en función de la información obtenida.

3.6 Conclusiones

Como resultado del análisis del incidente ocurrido a fines de octubre de 2025, se ha elaborado un conjunto de recomendaciones orientadas a **fortalecer la postura de seguridad de PRODUCTOS FERNÁNDEZ** y mitigar el riesgo de posibles nuevos ataques de denegación de servicio (DDoS). Este informe busca entregar al Directorio una visión clara sobre las acciones sugeridas y su impacto en la continuidad operacional del negocio.

En el corto plazo, se aplicaron **medidas de contención específicas**, consistentes en la **restricción geográfica de accesos** y la **incorporación de direcciones IP maliciosas a listas de bloqueo (botnets sites)**. Estas acciones permitieron reducir temporalmente el volumen de tráfico sospechoso y estabilizar los servicios afectados. Sin embargo, para consolidar una defensa más robusta y sostenible, se recomienda avanzar en un plan estructurado de mejoras técnicas.

En primer lugar, se **recomienda ajustar los parámetros de red** para limitar la cantidad de conexiones que pueden originarse desde una misma fuente. Este cambio técnico disminuiría la exposición a intentos masivos de conexión y contribuiría a una gestión más eficiente de los recursos de red. Asimismo, se sugiere **mantener y ampliar el perfil de geolocalización restrictivo**, revisando periódicamente los países o regiones que deben permanecer bloqueados según el contexto operacional.

De igual forma, se propone **activar los servicios avanzados de seguridad disponibles en el firewall perimetral**, como el sistema de prevención de intrusos (IPS), el escaneo profundo del tráfico (Full Scan) y la detección de redes de bots (Botnet Detection). Estas funciones permitirán identificar patrones anómalos y bloquear ataques en etapas tempranas, antes de que impacten la disponibilidad de los sistemas.

A mediano plazo, se **recomienda evaluar una evolución del modelo de acceso actual**, incorporando un **portal de autenticación (Access Portal)** que funcione como capa intermedia entre los usuarios y los servicios internos. Este enfoque, similar a un modelo de “acceso de confianza cero” (ZTNA), permitiría reforzar el control de acceso, verificando la identidad de cada usuario antes de permitir la conexión a recursos corporativos.

Asimismo, se **sugiere implementar un firewall especializado para aplicaciones web (WAF)**, con el objetivo de proteger los servicios expuestos en internet frente a ataques dirigidos específicamente al

nivel de aplicación, donde el firewall tradicional tiene limitaciones. Esta medida puede complementarse con la **activación del servicio DNSWatch**, que permite detectar comportamientos maliciosos y ataques basados en el sistema de nombres de dominio (DNS).

Por último, se **recomienda incorporar un mecanismo de autenticación multifactor (MFA)** en los accesos críticos, agregando una capa adicional de protección frente a intentos de ingreso no autorizados, incluso si las credenciales de usuario son comprometidas.

Desde EGS ponemos a disposición toda nuestra experiencia y capacidad para apoyarles en cada uno de estos puntos mencionados, además de habilitar el esfuerzo necesario dentro del Servicio Gestionado de Seguridad Perimetral Integral actualmente activo, además del Servicio Gestionado de Autenticación Multifactor actualmente en Proyectos.

En conjunto, estas recomendaciones apuntan a fortalecer la resiliencia tecnológica y operativa de **PRODUCTOS FERNÁNDEZ**, reduciendo significativamente la probabilidad e impacto de futuros ataques. Su implementación permitiría no solo proteger la continuidad del negocio, sino también **elevar el nivel de madurez en ciberseguridad**, alineándose con las mejores prácticas del sector y con los estándares internacionales vigentes.

3.7 Configuraciones recomendadas según Línea Base de Seguridad Firebox

Desde EGS proporcionamos el uso de un estándar de seguridad robusto en cada uno de nuestros servicios, en este caso particular, ese estándar que denominamos Línea Base de Seguridad para Firebox nos ayuda a identificar las siguientes configuraciones para mejorar la postura de seguridad frente a ataques DDOS:

A) Configuraciones globales

Actividad	Dónde (UI)	Ajuste/Política	Valor recomendado (Zero Trust)	¿Por qué? / Nota
Bloquear escaneos	Firewall → **Default Packet Handling**	**Block Port Scan** y **Block IP Scan**	**Activado**; umbral **10/s** (default)	Reduce ruido y descubre reconocimiento host/puerto.
Cuotas contra floods	Firewall → **Default Packet Handling**	**Per Server Quota**	Ver Tabla 2 (por servicio). Activar.	Limita conexiones/s por destino publicado (mitiga SYN/HTTP floods de baja/mediana escala).
		Per Client Quota	**20-50 conn/s por IP** (ver Tabla 2)	Corta bursts por IP atacante sin afectar multi-cliente legítimo.
Geoblocking	Services → **Geolocation**	Países permitidos	**Bloquear todo excepto** países de negocio; aplicar por **política**	Reduce superficie si no esperas tráfico global.
Auto-block de sitios	Firewall → **Default Packet Handling**	**Auto-block source IP of unhandled external packets**	**Activado** con lista de excepciones controlada	Castiga comportamiento anómalo (packets no mapeados).

Servicios de seguridad	Policy (cada política) → **Security Services**	**IPS (Full Scan)**	**Activado (Full Scan)** y firmas actualizadas	Bloquea exploits a servicios publicados.
		Botnet Detection	**Activado**	Corta C2/botnets que suelen orquestar DDoS.
		DNSWatch	**Activado**; forzar resoluciones vía DNS controlado	Evita dominios maliciosos usados en fases de ataque.

B) Sobre políticas de tráfico entrante

Servicio publicado	**Política/Proxy**	**Sources permitidos**	**Per Server Quota (conn/s)**	**Per Client Quota (conn/s por IP)**	**Otros ajustes clave**
HTTP/HTTPS (web/app)	**HTTPS-Proxy/HTTP-Proxy** (preferible a packet-filter)	IPs/CDN/ASN esperados; *idealmente* lista de allow	**300-600** (ajustar a tráfico normal)	**20-30**	Habilitar **IPS (Full Scan)**, **Botnet**, **DNSWatch**; limitar **países**; si hay WAF/CDN, publicar sólo detrás del CDN. Usar certificados válidos para politicas HTTPS Proxy, no autofirmados.
API sólo clientes	TCP/puerto específico (o HTTPS-Proxy con SNI/host)	**Sólo** rangos cliente/VPN	**100-200**	**10-20**	Autenticación fuerte a nivel app; rate-limit en backend.

C) Sobre perfil de geolocalización recomendado

Listado de países que según directrices de política de firewall de NIST SP 800-41 R1 y la situación de riesgo determinada por CISA y OFAC:

País (ISO-2)	Motivo principal de bloqueo	Fuentes federales	Prioridad
KP – Corea del Norte	Estado patrocinador de terrorismo; ciber-APT generadoras de ransomware y robo de criptomonedas	CISA «Nation-State Threats» L9-L10, OFAC «North Korea Sanctions» L11	**Alta**
IR – Irán	Estado patrocinador; oleadas de intrusiones a ICS y sector financiero	CISA L9-L10, OFAC L11	**Alta**
CU – Cuba	Estado patrocinador de terrorismo; sanciones financieras integrales	OFAC L9	Alta
SY – Siria	Estado patrocinador; múltiples programas de sanciones (PAARSS)	OFAC L12	Alta
RU – Rusia	Amenaza APT estratégica (APT29, Sandworm, etc.) y sanciones extensivas ("Russian Harmful Foreign Activities")	CISA L9-L10, OFAC L11	Alta
CN – China (PRC)	Principal origen de ciber-espionaje industrial; advisories de CISA	CISA L9-L10	Alta
BY – Bielorrusia	Actor aliado en campañas rusas; sanciones económicas (2024)	OFAC L8	Alta
VE – Venezuela	Sanciones sector energía y corrupción; actividad de phishing regional	OFAC L12	Media
MM – Birmania/Myanmar	Junta militar sancionada (2021-2025); botnets y spam	OFAC L8	Media
SD – Sudán	Sanciones (Sudán y Darfur); presencia de grupos TCO y fraude	OFAC L12	Media
NI – Nicaragua	Sanciones por corrupción y represión política; ciber-fraude	OFAC L11	Media

LY – Libia	Sanciones ONU/OFAC; infraestructura botnet persistente	OFAC L11	Media
SO – Somalia	Sanciones por terrorismo marítimo; alto volumen de scanning	OFAC L12	Media
NL – Paises Bajos	Origen de botnets masivos	NSOC EGS	Media

Según identificación para este Incidente, también recomendamos incluir a Pakistán, Canadá, Israel y Brasil como orígenes no permitidos.